

Detecting Web Attacks

By Patrick Ofori-Sampong

Scenario:

We receive a log indicating a possible attack, can you gather information from the .pcap file?
Log file: /root/Desktop/ChallengeFile/webserver.em0.pcap

Objective:

Investigate a possible attack using the provided .pcap network capture and extract evidence of suspicious activity.

Tools Used:

Wireshark (for packet capture analysis)

Challenge 1:

How many HTTP GET requests are in pcap?

Opened the .pcap file (webserver.em0.pcap) in Wireshark.

http.request						
No.	Time	Source	Destination	Dst Port	Protocol	Info
12	64.550254	192.168.63.20	1.1.1.5	80	HTTP	GET / HTTP/1.0
21	67.564082	192.168.63.20	1.1.1.5	80	HTTP	GET / HTTP/1.0
37	201.439138	192.168.63.50	1.1.1.5	80	HTTP	GET / HTTP/1.1
47	221.922660	192.168.63.20	1.1.1.5	80	HTTP	GET / HTTP/1.0
57	224.938759	192.168.63.20	1.1.1.5	80	HTTP	GET / HTTP/1.0

Answer: 5

Challenge 2:

What is the server operating system?

Followed the HTTP response headers to inspect server metadata.

Found the Server field in the header, which revealed the operating system.

Wireshark · Follow HTTP Stream (tcp.stream eq 0) · webserver.em0.pcap

```
GET / HTTP/1.0
Host: 192.168.63.100
Accept: text/html, text/plain, text/css, text/sgml, */*;q=0.01
Accept-Encoding: gzip, compress, bzip2
Accept-Language: en
User-Agent: Lynx/2.8.7rel.1 libwww-FM/2.14 SSL-MM/1.4.1 OpenSSL/0.9.8n

HTTP/1.1 401 Authorization Required
Date: Thu, 20 Jan 2011 07:36:27 GMT
Server: Apache/2.2.15 (FreeBSD) DAV/2 mod_ssl/2.2.15 OpenSSL/0.9.8n
WWW-Authenticate: Basic realm="Restricted"
Content-Length: 401
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>401 Authorization Required</title>
</head><body>
<h1>Authorization Required</h1>
<p>This server could not verify that you
are authorized to access the document
requested. Either you supplied the wrong
credentials (e.g., bad password), or your
browser doesn't understand how to supply
the credentials required.</p>
</body></html>
```

Answer: FreeBSD

Challenge 3:

What is the name and version of the web server software?

Answer: Apache/2.2.15

Challenge 4:

What is the version of OpenSSL running on the server?

Answer: OpenSSL/0.9.8n

Challenge 5:

What is the client's user-agent information?

Answer: Lynx/2.8.7rel.1 libwww-FM/2.14 SSL-MM/1.4.1 OpenSSL/0.9.8n

Challenge 6:

What is the username used for Basic Authentication?

The image shows a Wireshark packet capture of an HTTP transaction. The top pane displays the raw packet data for a GET request to 192.168.63.100. The request headers include Accept, Accept-Encoding, Accept-Language, User-Agent (Lynx/2.8.7rel.1 libwww-FM/2.14 SSL-MM/1.4.1 OpenSSL/0.9.8n), and Authorization: Basic d2ViYWRTaw46VzNiNERtMW4=. The response headers include Date, Server (Apache/2.2.15), Last-Modified, ETag, Accept-Ranges, Content-Length, Connection, and Content-Type. The response body is <html><body><h1>It works!</h1></body></html>. Below the packet capture, a Base64 decoder is shown with the input 'd2ViYWRTaw46VzNiNERtMW4=' and the output 'webadmin:W3b4Dm1n'.

```
GET / HTTP/1.0
Host: 192.168.63.100
Accept: text/html, text/plain, text/css, text/xml, */*;q=0.01
Accept-Encoding: gzip, compress, bzip2
Accept-Language: en
User-Agent: Lynx/2.8.7rel.1 libwww-FM/2.14 SSL-MM/1.4.1 OpenSSL/0.9.8n
Authorization: Basic d2ViYWRTaw46VzNiNERtMW4=

HTTP/1.1 200 OK
Date: Thu, 20 Jan 2011 07:39:08 GMT
Server: Apache/2.2.15 (FreeBSD) DAV/2 mod_ssl/2.2.15 OpenSSL/0.9.8n
Last-Modified: Mon, 27 Dec 2010 13:11:28 GMT
ETag: "3f44b-2c-4986412e52000"
Accept-Ranges: bytes
Content-Length: 44
Connection: close
Content-Type: text/html

<html><body><h1>It works!</h1></body></html>
```

From Base64

Alphabet
A-Za-z0-9+/=

☒ Remove non-alphabet chars ☐ Strict mode

Output

webadmin:W3b4Dm1n

Answer: webadmin

Challenge 7:

What is the user password used for Basic Authentication?

Answer: w3b4Dm1n